IS CYBERNEXT 2026 · CYBERSECURITY TRACK

ReverseShield

Reverse-Engineering Exposure Workbench

“See what your build reveals — before an attacker does.”

Local | Static-only | Evidence, not a verdict

Naser · Zayed · Nomai · Faisal

Four-person student team · working prototype, built and tested locally

A shipped binary is a readable document

- Symbols, debug information, build paths and plaintext messages often survive release.
- An attacker starts from the binary — no source code required.
- Ghidra-class decompilers recover structure, constants and readable logic.
- Teams rarely see their own build the way an attacker does.

Not a hypothetical: the original Level 5 sample showed exactly these artefacts.

WHAT A BUILD CAN LEAK

```
$ strings app
  /home/dev/policy-engine/…
  "tenant is not set"
  "blocked by policy flag"

$ readelf -s app
  35 symbol-table entries
  .debug_info present

$ ghidra
  policy_allows() reconstructed
```

Existing tools answer different questions

Packers & obfuscators

Claim protection. Rarely show what an analyst can still recover.

Vulnerability scanners

Return CVE/CWE verdicts — not binary exposure evidence.

Manual Ghidra work

Powerful, but expert-only, ad hoc and hard to reproduce.

The gap: a safe, repeatable way to see binary exposure, change a copy, and verify what the change removed — without executing the target.

Analyze → transform a copy → reanalyze → compare

1
Select
ELF/PE, package, app or sample

2
Analyze
bounded static tools + optional Ghidra

3
Transform
a copy only — original untouched

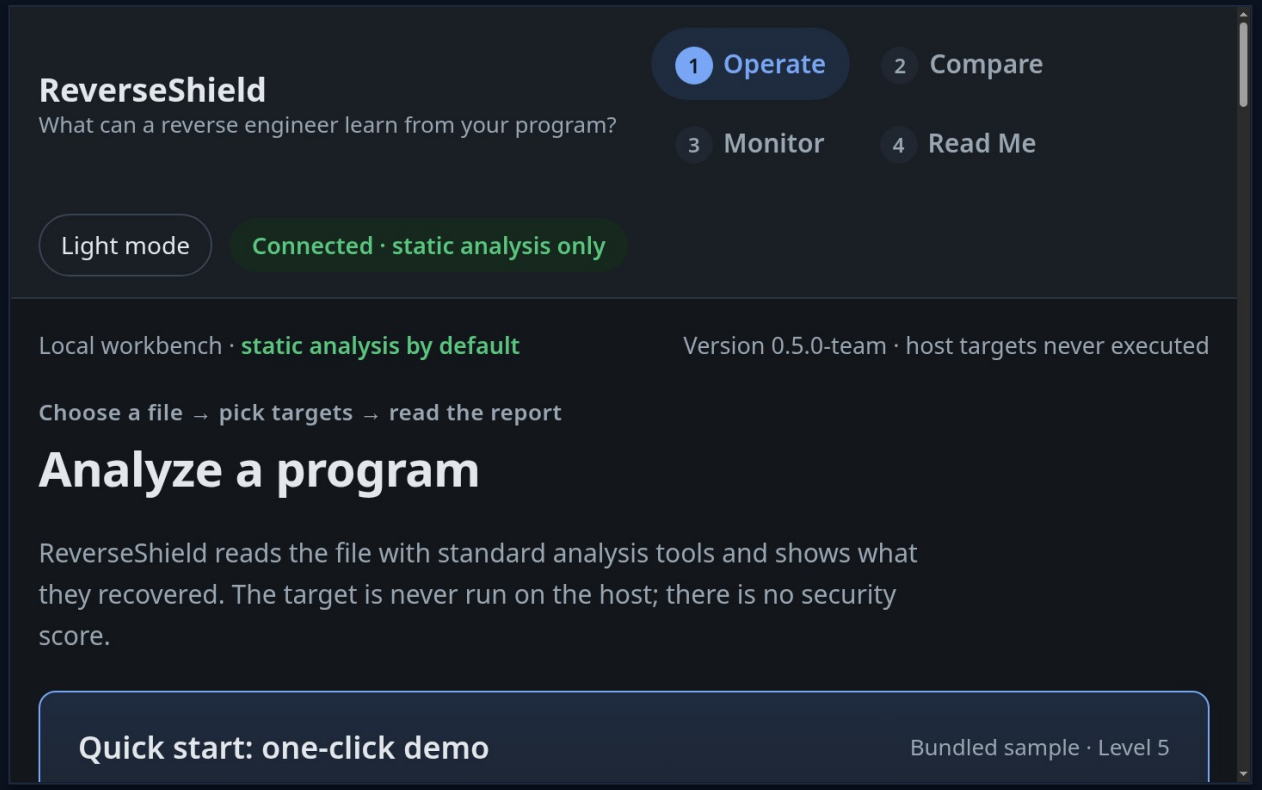
4
Reanalyze
same tools, same settings

5
Compare
qualified evidence, not a score

- Local loopback server; no cloud upload and no target execution on the host.
- Every job keeps a private snapshot, live event log and report under runs/<job>.
- Claims stay bounded: observations and hashes, never a universal protection score.

Built as a local workbench, not a slide demo

- Analyzes Linux ELF and Windows PE files; discovers Flatpak apps, folders, RPM payloads and uploads.
- Runs readelf, objdump, strings, nm and optional project-local Ghidra headless.
- Six self-authored samples ship with the project for reproducible demonstrations.
- Reports: plain-language findings, metrics, functions, pseudocode, call graphs and raw output.



Real local UI, 11 Nov 2026 · static analysis only

What the report actually reveals

Signal	Why an analyst cares
Names & symbols	Function and variable names make logic easier to follow.
Debug information	Source paths, build flags and compiler details.
Strings & messages	URLs, internal messages, policy text, hardcoded values.
Imports & exports	Capabilities and the public interface of the build.
Functions & pseudocode	Recovered structure and readable C-like logic.
Call graph & CFG	How execution flows between routines.
Hardening properties	Observed NX, PIE, RELRO, canary, FORTIFY and PE flags.

Exposure evidence for a human decision — not a vulnerability verdict and not a security score.

The comparison is the claim

- ELF symbol-table entries: 35 → 0
- Byte-scan strings: 134 → 60
- File size: 15,904 → 10,784 bytes
- Debug sections and symbol table: present → absent

Counts come from named tools. N/A means unmeasured, never zero. A smaller file is not automatically safer.



Static mitigation posture, with evidence

Property	Level 5 original	Level 5 hardened
NX / DEP	Present	Present
PIE / ASLR	Absent	Present
RELRO	Partial	Full
Stack canary	Absent	Present
FORTIFY	Absent	Present

Observed file properties. Presence is not a guarantee; absence is not exploitability.

Exploit-mitigation properties

Protection	Result	Evidence
NX / DEP	**Present**	PT_GNU_STACK is non-executable (PF_X clear).
PIE / ASLR	**Present**	ET_DYN with DF_1_PIE set.
RELRO	**Present**	PT_GNU_RELRO and BIND_NOW are present (full RELRO).
Stack canary	**Present**	Found __stack_chk_fail
FORTIFY	**Present**	Found __printf_chk

Present and absent are observed binary properties. They are not a security score; absence does not prove exploitability and presence is not a guarantee.

A real source transformation — on our own samples only



- Level 5: 15,904 → 109,296 bytes; all six policy messages removed from plaintext.
- ELF symbol table 35 → 0; Ghidra labels and generated code increase, so aggregate counts rise.
- Entropy 2.9213 → 6.4849 bits/byte; Ghidra still recovers the logic and takes longer.
- Obfuscation raises analysis cost — it is not proof of protection.

Scope: five original bundled sample sources. Arbitrary ELF/PE files remain analysis-only — a compiler pass cannot transform a binary without source.

Behaviour check with a narrow, stated scope

WHAT RUNS

- Separate original and protected driver builds.
- Packed into a minimal initramfs with a host kernel.
- QEMU micro-VM: no disk, no network, serial output only.
- Transcripts and exit codes compared; five self-authored samples.
- Every transcript and driver hash recorded in evidence.

RESULT

5 / 5

deterministic driver vectors matched

```
exit codes 0 / 0   ·   QEMU return code 0

scope: separate_deterministic_drivers

artifact behaviour verified: false
```

Critical scope: the guest ran separate driver builds, NOT the downloadable protected ELF. behavior_verified remains false for that artifact; matching vectors are not full equivalence.

Local architecture and trust boundary



Host targets are never executed. Only copies are transformed; QEMU is limited to separate deterministic sample drivers.

Security posture and what backs it

Control / check	Evidence
Loopback + session token	Every API read/write rejected without the per-session token
Same-origin / CSP	Host, Origin, Referer and fetch-site checks; strict CSP
No host target execution	Static tools read bytes; copies only; QEMU sample drivers isolated
Operation/profile validation	Analysis jobs cannot dispatch a transformation (tested at HTTP level)
Test suite	167 tests, 1 skipped — Ghidra-enabled, passed
SAST / secret scan	Bandit 0 high, 3 medium (tests only); detect-secrets: checksums/fixtures only
Sample privacy & package	DWARF paths removed; 101-entry ZIP extracted and re-tested

Boundaries: the token is CSRF protection, not multi-user IAM; static parsers are not a malware sandbox.

Where ReverseShield fits

	Packer / protector	Vulnerability scanner	Manual Ghidra	ReverseShield
Primary output	Claimed protection	CVE/CWE verdict	Expert notes	Exposure evidence
Before / after	Rarely measured	Not applicable	Ad hoc	Bounded and repeatable
Target execution	Runtime loader	Often none	Possible	Never on the host
Works from binary	Yes	Yes	Yes	Yes (ELF/PE)
States limits	Marketing copy	CVE database scope	Analyst judgement	Built into the report

We do not claim to out-protect commercial tools. We make the comparison auditable and keep the limits visible.

What we do not claim

NOT CLAIMED

- That a build is “secure” or “unhackable”.
- CVE/CWE detection, risk scores or exploitability.
- Full behavioural equivalence from five vectors.
- Protection of arbitrary third-party binaries.
- Native-Windows OLLVM or a hardened sandbox.

KNOWN GAPS

- Windows manual acceptance is still pending.
- QEMU tests separate drivers, not the downloadable ELF.
- Semgrep and ZAP were not re-run on this tree.
- Parser isolation and full dynamic analysis are future work.
- OLLVM is limited to the five original sample sources.

Every item above maps to an acceptance-matrix row or a documented test boundary — not a footnote added at the end.

From prototype to a repeatable release gate

NOW · 0.5

Evidence-first prototype

- ELF/PE static analysis
- Six samples
- OLLVM + QEMU scope
- Local release candidate

NEXT

Release readiness

- Windows manual acceptance
- Signed, reproducible ZIP
- CI on every change
- Pilot with two teams

RESEARCH

Deeper evidence

- Isolated dynamic lab
- SBOM / CVE correlation
- More formats
- Larger benchmark set

The near-term goal is trust: reproducible builds, clean-platform evidence, and pilots that test whether the report changes release decisions.

TEAM

Four people, one evidence chain

Naser

Day 1 · Windows & PE

Setup, PE acceptance, first-run reliability

Zayed

Day 2 · Analysis accuracy

Metrics, Ghidra integration, one-click demo

Nomai

Day 3 · Security & API

Token checks, sanitizer, SAST/DAST evidence

Faisal

Day 4 · Integration

Release packaging, docs, evidence, demo

Evidence, not verdicts.

We are looking for technical feedback, a pilot team, and a reason to make the next build safer.